

Корелација догађаја, ефективност контрола и учење

Корелација догађаја, процена контрола и постинцидентна анализа



Садржај презентације

01

Догађаји

Контекст, идентификатор и корелација.

05–10

02

Контроле

Сценарио, мера и свеж доказ.

11–16

03

Одговор

Последице радње и људска одлука.

17–21

04

Учење

Повратна спрега и пројектна провера.

22–30

Увод

Предмет анализе и основни појмови (03–04).

Корелација и ефективност контрола

Догађаји добијају значење кроз заједнички контекст, а контрола се процењује на основу актуелног и проверљивог доказа.

ПРЕДМЕТ АНАЛИЗЕ

Ризик који се анализира

Процена безбедности обухвата везу између догађаја, контрола и доказа. Корелација даје контекст догађајима, а актуелан доказ омогућава процену рада контроле и последица инцидента.

ЗНАЧАЈ

Значај за безбедност система

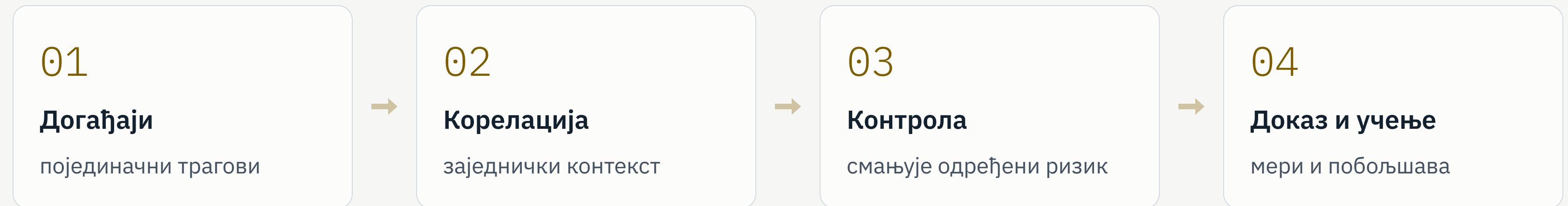
Мерење ефективности спречава лажни осећај сигурности. Контрола која постоји, али је погрешно подешена, никада тестирана или без власника, не заслужује исто поверење као контрола са проверљивим доказом.

КРИТЕРИЈУМ ПРОВЕРЕ • Проверљив резултат

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

Основни појмови

Догађаји, корелација, контрола и доказ омогућавају процену стварног безбедносног исхода.



ЗАКЉУЧАК

Безбедност напредује кроз повратну спрегу: доказ мења разумевање ризика, а то мења контролу.

01

ПРВИ ДЕО

Догађаји и контекст

Трагови добијају значење када их повежемо са актером, ресурсом и током.

Време

Актер

Ресурс

Correlation ID

Догађаји

појединачни трагови

01 Догађај бележи време, актера, ресурс, тип и идентификатор тока.

Питање: који улаз покреће ову одлуку?

02 Један догађај ретко је довољан за закључак, значење долази из везе са другима.

Питање: која граница мора бити видљива?

03 Приказано правило захтева идентификатор тока за поуздано повезивање догађаја.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који подаци морају постојати у сваком догађају да би се касније могао повезати са другима?

Траг једног корисничког тока

Илустративни низ повезаних догађаја у једној интеракцији.

Један ток · correlationId = flow-42

Пријава
актер и исход



Пристап ресурсу
радња и циљ



Одлука контроле
исход и разлог

Тумачење

Идентификатор интеракције треба сачувати када систем већ зна да догађаји припадају истом току.

Корелација

заједнички контекст

01 Корелација групише догађаје истог тока у један случај.

Питање: који улаз покреће ову одлуку?

02 Случај чува број догађаја и скуп њихових типова, без дуплирања.

Питање: која граница мора бити видљива?

03 Правило корелације се тестира познатим низом догађаја и очекиваним случајем.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који низ догађаја у вашем систему заједно значи више него сваки појединачно?

Корелација гради причу, не закључак из једног записа

C# • илустративни пример

```
1  public IReadOnlyList<CorrelationCase> Correlate(  
2      IEnumerable<SecurityEvent> events)  
3  {  
4      return events  
5          .GroupBy(securityEvent =>  
6              securityEvent.CorrelationId)  
7          .Select(group => new CorrelationCase(  
8              group.Key,  
9              group.Count(),  
10             group.Select(securityEvent => securityEvent.Type)  
11                 .ToHashSet(StringComparer.OrdinalIgnoreCase)))  
12         .ToArray();  
13 }
```

ТУМАЧЕЊЕ

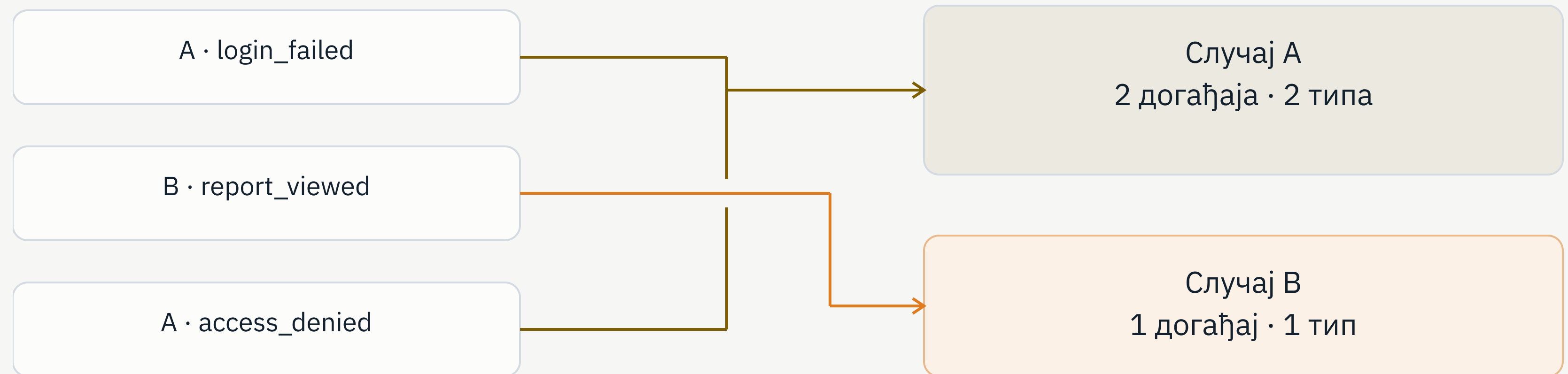
Correlation ID повезује појединачне догађаје у случај са бројем догађаја и скупом типова.

БЕЗБЕДНОСНА ГРАНИЦА

Груписање по идентификатору не доказује узрок. Случај је контекст за даљу процену.

Груписање по correlation ID

Догађаји различитих токова не спајају се само зато што су настали близу.



Тумачење

Приказани код броји догађаје и сакупља јединствене типове. За закључак о нападу потребна је додатна анализа.

02

ДРУГИ ДЕО

Контрола и доказ

Ефективност се мери за одређени сценарио и познат опсег примене.

Ризик

Покривеност

Циљ

Свежина

Контрола

смањује одређени ризик

01 Контрола је везана за конкретан ризик који смањује и за ток на који се примењује.

Питање: који улаз покреће ову одлуку?

02 У наставном примеру ефективност је удео заустављених у односу на све испитане покушаје.

Питање: која граница мора бити видљива?

03 Контрола која никада није била на проби не сматра се ефективном.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Којим бројем бисте показали да ваша контрола заиста зауставља покушаје?

Мера ефективности у наставном примеру

Удео је једна мера, уз коју се бележе сценарио, извор података и ограничења.

$$E = \frac{\text{број заустављених покушаја}}{\text{број свих испитаних покушаја}} \times 100\%$$

Илустрација

90 заустављених од 100 испитаних покушаја = 90%. Резултат важи за приказани сценарио и скуп покушаја.

Без покушаја

Нема довољно мерења за оцену. Нула у приказаном коду је договорена повратна вредност, а не доказ да је контрола лоша.

Контрола без мерења не важи као ефективна

C# • илустративни пример

```
1  [Test]
2  public void
3      Evaluate_WhenControlWasNeverExercised_DoesNotClaimItWorks()
4  {
5      var effectiveness = _calculator.Evaluate(
6          new ControlMeasurement("step-up", 0, 0));
7      using (Assert.EnterMultipleScope())
8      {
9          Assert.That(effectiveness.Ratio, Is.Zero);
10         Assert.That(effectiveness.MeetsTarget, Is.False);
11     }
12 }
```

ДОКАЗ

Без иједног покушаја удео је нула, а циљ се не сматра испуњеним.

ОЧЕКИВАНИ ИСХОД

Тест не дозвољава да одсуство мерења изгледа као успех контроле.

Доказ, покривеност и ефективност

Поређење приказује функцију сваког елемента и ограничење његове самосталне примене.

Питање	Слаб одговор	Поуздан одговор
Да ли контрола постоји?	Класа или подешавање је присутно.	Контрола има власника, активну конфигурацију и сврху.
Да ли ради?	Једном је ручно проверена.	Постоји поновљив тест или актуелан оперативни доказ.
Шта покрива?	Претпоставља се да важи свуда.	Познати су сценарио, граница и изузеци.
Како знамо да је ослабила?	Проблем се види тек после инцидента.	Метрика, alert или редован преглед откривају одступање.

Запис о процени контроле

JSON · илустративни пример

```
1  {  
2    "control": "object-authorization",  
3    "risk": "cross-tenant-access",  
4    "lastEvidence": "2026-09-20",  
5    "coveredScenario": "foreign-record-denied",  
6    "status": "effective",  
7    "nextReview": "2026-10-20"  
8  }
```

Повезан ревизиони траг

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, token, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

03

ТРЕЋИ ДЕО

Процена и одговор

Повезани догађаји усмеравају процену, а последице одговора одређују потребне провере.

Контекст

Последица

Одобрење

Ревизиони траг

Контрола има смисао тек уз доказ

Наведена правила остају видљива у имплементацији, тестовима и ревизији.

01 Корелација повезује догађаје по времену, актеру и ресурсу, уз садржај појединачних порука лога.

Јасно правило

02 Одговор са већим последицама захтева људску одлуку и јасан траг одобрења.

Проверљива примена

03 Постинцидентни преглед испитује системске и процесне узроке догађаја.

Видљив доказ

Случај: контрола постоји, али нема свеж доказ

Случај повезује опште правило са конкретним контекстом, серверском провером и очекиваним исходом.

СЦЕНАРИО

Пример: контрола постоји, али нема свеж доказ

Систем има правило које ограничава приступ осетљивом ресурсу. Правило је било успешно тестирано пре неколико месеци, али се у међувремену променио модел улога и додат је нови улаз у систем. Без новог доказа тим зна да контрола постоји, али не зна да ли још покрива стварни ризик. Ефективност зато укључује свежину, опсег и резултат провере.

- 01 Корелација повезује низ догађаја у једну причу о понашању система.
- 02 Мера ефективности прати да ли контрола има власника, доказ и покривеност релевантног сценарија.
- 03 Аутоматизован одговор може убрзати реакцију, али радња са великом последицом задржава људску потврду и ревизиони траг.

Процена ефективности контроле

Процена користи актуелан доказ, покривеност релевантних сценарија и позната ограничења.

ОБРАЗЛОЖЕЊЕ

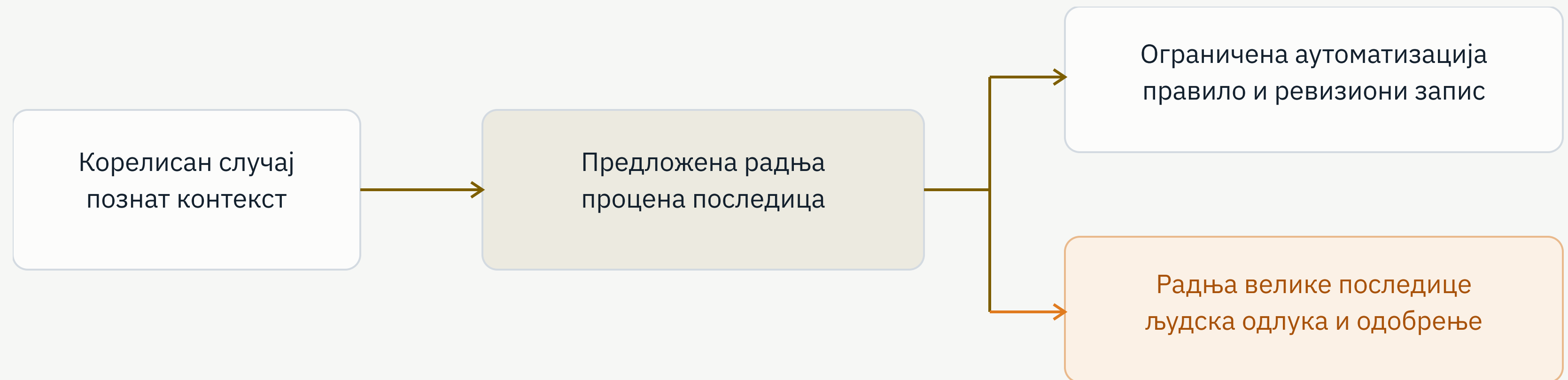
ЕФЕКТИВНОСТ КОНТРОЛЕ

Контрола може бити имплементирана, али погрешно подешена, заобиђена новим током или застарела после промене система. Зато се њена ефективност процењује кроз доказ: последњи успешан тест, покривени сценарио, власника и способност да се проблем примети ако контрола закаже.

- 01 Доказ се освежава када се промени релевантан ток, улога или граница поверења.
- 02 Мера ефективности јасно приказује области за које нема довољно доказа.
- 03 Квалитетна анализа повезује ризик, контролу, тест и преостало ограничење у једну јасну причу.

Граница аутоматизованог одговора

План реакције одређује које су радње унапред дозвољене.



Тумачење

Корелација сама не даје овлашћење за сваку радњу. Приказани наставни модел задржава људску потврду за велики утицај.

04

ЧЕТВРТИ ДЕО

Учење и побољшање

Доказ мења процену ризика, а процена усмерава следећу измену контроле.

Резултат

Преостали ризик

Промена

Поновна провера

Доказ и учење

мери и побољшава

01 Доказ ефективности мора бити свеж, после промене тока оцена се поново утврђује.

Питање: који улаз покреће ову одлуку?

02 Циљни удео је унапред одређен, па се резултат пореди са прагом, а не са утиском.

Питање: која граница мора бити видљива?

03 Резултат мерења води до корекције контроле или до прихватања преосталог ризика.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који ризик контрола ублажава, који доказ чува и који сигнал показује да је престала да ради?

Безбедносна повратна спрега

Процес приказује улазе, место одлуке и доказ који остаје после исхода.

КОНТЕКСТ

Безбедносна повратна спрега

Зрео систем не завршава безбедност имплементацијом контроле. Догађаји и тестови стварају доказ, доказ мења процену ризика, а процена ризика води ка бољој политици или другачијој контроли. Тако се избегава лажни осећај да је једном завршени посао заувек довољан.

- 01 Догађај или тест открива образац који захтева пажњу.
- 02 Корелација повезује образац са имовином, актером и контролом.
- 03 Тим проверава да ли постојећа контрола покрива стварни сценарио.
- 04 Нова одлука ствара ажурирану политику, тест или оперативну процедуру.

Примена у развоју

Тим примењује тему кроз серверске провере, тестове и ревизионе записе током развоја.

РАЗВОЈНИ КОНТЕКСТ

Примена принципа у коду

Добра безбедносна анализа показује узрочну везу: коју имовину штитимо, који сценарио разматрамо, која контрола делује и како знамо да њено понашање још увек одговара намери. Кратак, јасан доказ вреди више од дуге листе функционалности.

01 Дефинисана одлука и њена граница.

02 Серверска имплементација провере.

03 Позитиван и негативан доказ.

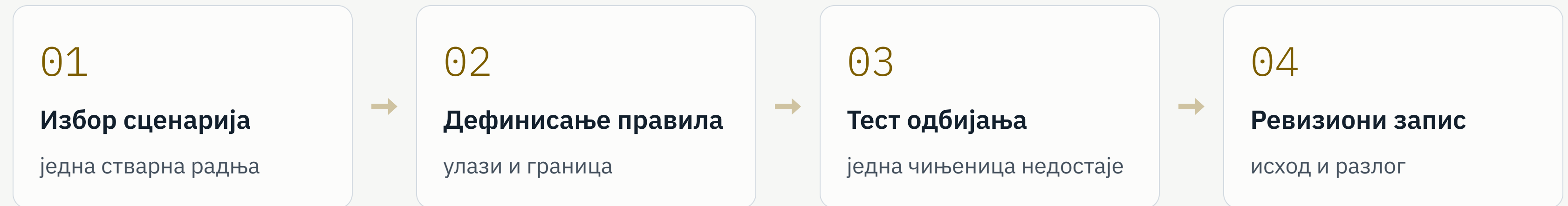
Честе грешке у имплементацији

Грешке настају када контекст, место одлуке или доказ остану нејасни.

-
- 01** Закључивање из једног догађаја без ширег контекста.
Нема јасног власника одлуке.
 - 02** Аутоматска акција са великом последицом без заштитне провере.
Не постоји негативан сценарио.
 - 03** Оцена контроле само по томе да ли је имплементирана.
Доказ не показује стварни исход.
-

Примена на пројекат

Анализа једног сценарија обухвата одлуку, имплементацију, тест одбијања и доказ.

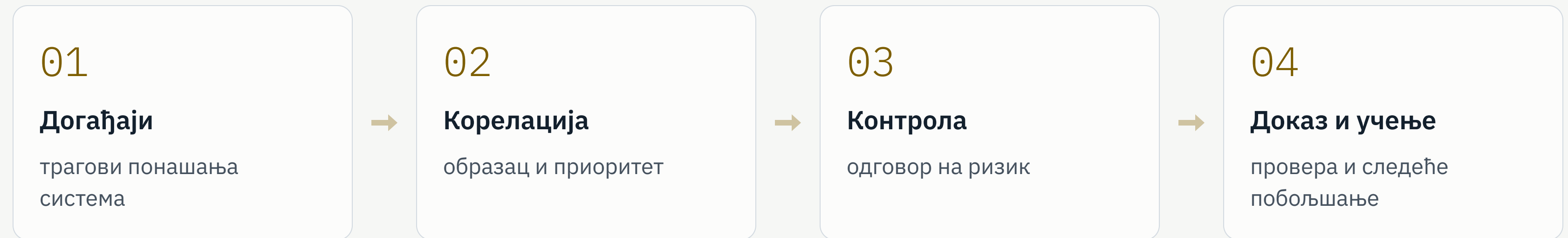


ПРИМЕНА НА ПРОЈЕКАТ

Пројектна примена теме „Корелација догађаја, ефективност контрола и учење“ обухвата једну серверску одлуку, тест одбијања и доказ који други члан тима може да понови.

Модел континуираног унапређивања безбедности

Безбедност напредује кроз повратну спрегу. Доказ мења разумевање ризика, а то мења контролу.

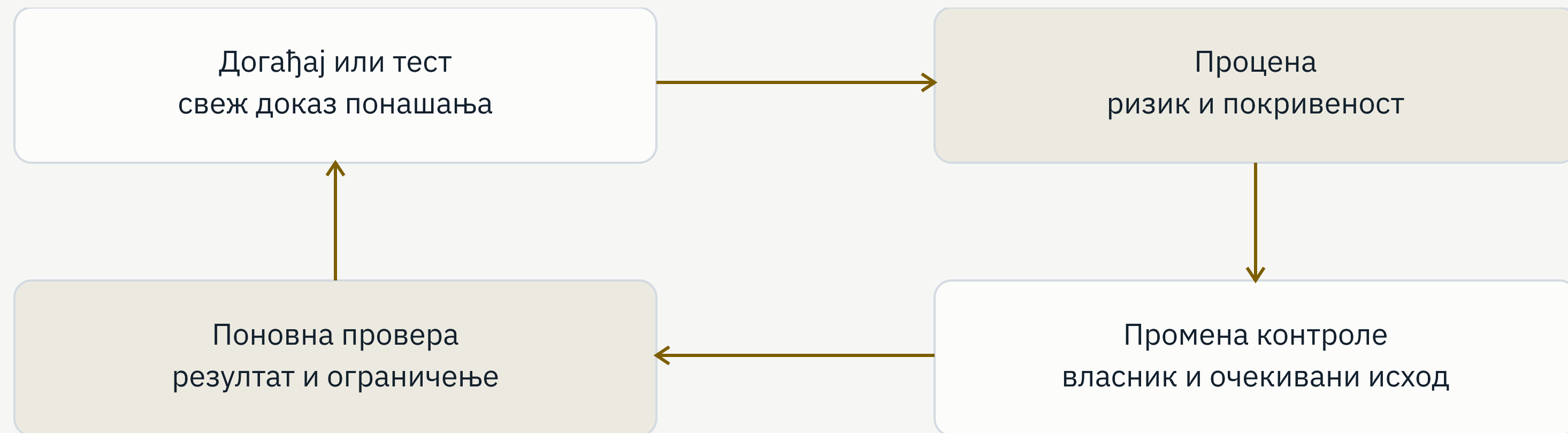


ЕЛЕМЕНТИ АНАЛИЗЕ

Анализа сваког корака обухвата покретача, место одлуке и траг који остаје после исхода.

Круг континуираног побољшања

Промена система враћа процену контроле на проверу стварног сценарија.



Тумачење

Нови резултат допуњује знање о ризику. Прихваћено ограничење остаје видљиво и има рок за следећи преглед.

Провера разумевања

Разумевање теме подразумева објашњење одлуке и доказа независно од конкретног технолошког оквира.

Догађаји

појединачни трагови

Корелација

заједнички контекст

Контрола

смањује одређени ризик

Доказ и учење

мери и побољшава

Који ризик контрола ублажава, који доказ чува и који сигнал показује да је престала да ради?

Пројектна примена: применити исти модел на једну реалну границу у сопственом пројекту.